Romney, M.B et.all (2021). Accounting Information Systems 15th: Chapters 10

AIS

Kiểm soát nội bộ
Internal control

Nguyễn Bích Liên

Mục tiêu

1. Hiểu khái quát về ba khuôn mẫu kiểm soát: COBIT, COSO (kiểm soát nội bộ-IC & ERM)
2. Hiểu các thành phần của kiểm soát nội bộ
3. Hiểu mối quan hệ giữa các thành phần Kiểm soát nội bộ
4. Hiểu lưu ý kiểm soát nội bộ trong doanh nghiệp nhỏ

Nội dung

1. Một số khái niệm cơ bản
2. Các thành phần của kiểm soát nội bộ
3. Mối quan hệ giữa các thành phần kiểm soát nội bộ
4. Giới thiệu về 3 khuôn mẫu kiểm soát
5. Lưu ý KSNB đối với doanh nghiệp nhỏ

Thuật ngữ

Thuật ngữ	Trang tham chiếu	Dịch
Application controls		Kiểm soát ứng dụng
Audit committee		Ủy ban kiểm toán
Audit trail		Dấu vết kiểm toán
Authorization		Ủy quyền
Background check		Kiểm tra thông tin cá nhân/ kiểm tra lý lịch
Chief compliance officer (CCO)		Giám đốc tuân thủ
Conclusion		Thông đồng
Committee of sponsoring Organizations (COSO)		Ủy ban của các tổ chức bảo trợ - Ủy ban COSO
Compliance objectives		Mục tiêu tuân thủ
Computer forensics specialists	346	Các chuyên gia bảo mật về gian lận máy tính

Thuật ngữ

Thuật ngữ	Trang tham chiếu	Dịch
Computer security officer (CSO)		Nhân viên an ninh máy tính
Control activities		Các hoạt động kiểm soát
Corrective control		Kiểm soát sửa chữa/bù đắp
Data processing schedule		Lịch trình xử lý dữ liệu
Detective controls		Kiểm soát phát hiện
Digital signature		Chữ ký điện tử
Enterprise Risk Management – Integrated Framework (ERM)		Khuôn mẫu tích hợp về quản trị rủi ro doanh nghiệp
Event		Sự kiện
Expected loss		Mức thiệt hại kỳ vọng
Exposure or impact		Mức tác động /thiệt hại

Thuật ngữ

Thuật ngữ	Trang tham chiếu	Dịch
Forensic investigator	346	Các nhà điểu tra pháp ý máy tính/điều tra gian lận máy tính
Fraud hotline		Số điện thoại khẩn để báo cáo gian lận
General authorization		Ủy quyền chung
General controls		Kiểm soát chung
Inherent risk		Rủi ro tiềm tàng
Internal control		kiểm soát nội bộ
Internal environment		Môi trường nội bộ

Tại sao cần KSNB

What is Internal Control?

Internal control includes everything an organization does to protect its:



- People
- Reputation
- Property
- Cash
- Equipment
- Information
- Ability to operate into the future

What Can Controls Do?

Controls can:

- Increase revenue
- Save money
- Prevent accidents
- Deter fraud
- Detect problems
- Save information
- Correct errors
- Protect people and property



Why Do We Need Internal Control? What Can Happen?

Losses can result from:

- Fire
- Flood
- Theft
- Fraud
- Waste
- Lawsuits
- Accidents and injuries
- Customer taking business elsewhere







What Are Some Examples of Controls?

- Alarm systems
- Locks
- Safety shoes
- Instruction and training for employees
- Inventory counts
- Budgets
- Signatures on time sheets
- Independent reviews







1. Một số khái niệm cơ bản

Kiểm soát nội bộ (internal control). Là *qui trình* được thiết kế và thực hiện để cung cấp sự *đảm bảo hợp lý đạt được* các *mục tiêu kiểm soát*:

❖Hoạt động

- Bảo vệ tài sản: Đạt/có được, sử dụng hoặc định đoạt
- Đẩy mạnh và nâng cao hiệu quả hoạt động.

❖Báo cáo

- Duy trì ghi chép đầy đủ chi tiết để báo cáo tài sản của công ty một cách chính xác và công bằng.
- Cung cấp thông tin chính xác và đáng tin cậy.
- Lập báo cáo tài chính theo các tiêu chí đã thiết lập.

❖Tuân thủ

- Khuyến khích tuân thủ các chính sách quản lý
- Tuân thủ luật pháp và quy định hiện hành

1. Một số khái niệm cơ bản

- Có 4 cấp độ kiểm soát giúp điều hòa xung đột giữa kiểm soát (control) và sự sáng tạo (creavity)
  - **Hệ thống niềm tin (belief system).** Mô tả cách công ty tạo giá trị, giúp nhân viên hiểu tầm nhìn quản lý, truyền thông giá trị cốt lõi, truyền cảm hứng cho nhân viên sống theo những giá trị đó
  - **Hệ thống ranh giới (boundary system).** Thiết lập ranh giới với hành vi nhân viên
  - **Hệ thống chuẩn đoán (Diagnostic system).** Đo lường, giám sát và so sánh giữa thực tế và mục tiêu hoặc ngân sách. -> điều chỉnh
  - **Hệ thống kiểm soát tương tác (Interactive control system).** Giúp người quản lý hướng sự tập trung của nhân viên vào vấn đề chiến lược cũng như sự tham gia của họ vào các quyết định

1. Một số khái niệm cơ bản

- Có 4 cấp độ kiểm soát giúp điều hòa xung đột giữa kiểm soát (control) và sự sáng tạo (creavity)
  - **Hệ thống niềm tin (belief system).** Mô tả cách công ty tạo giá trị, giúp nhân viên hiểu tầm nhìn quản lý, truyền thông giá trị cốt lõi, truyền cảm hứng cho nhân viên sống theo những giá trị đó
  - **Hệ thống ranh giới (boundary system).** Thiết lập ranh giới với hành vi nhân viên
  - **Hệ thống chuẩn đoán (Diagnostic system).** Đo lường, giám sát và so sánh giữa thực tế và mục tiêu hoặc ngân sách. -> điều chỉnh
  - **Hệ thống kiểm soát tương tác (Interactive control system).** Giúp người quản lý hướng sự tập trung của nhân viên vào vấn đề chiến lược cũng như sự tham gia của họ vào các quyết định

2. Các thành phần Kiểm soát nội bộ

Mục lục

2.1. Đánh giá và phản ứng với rủi ro

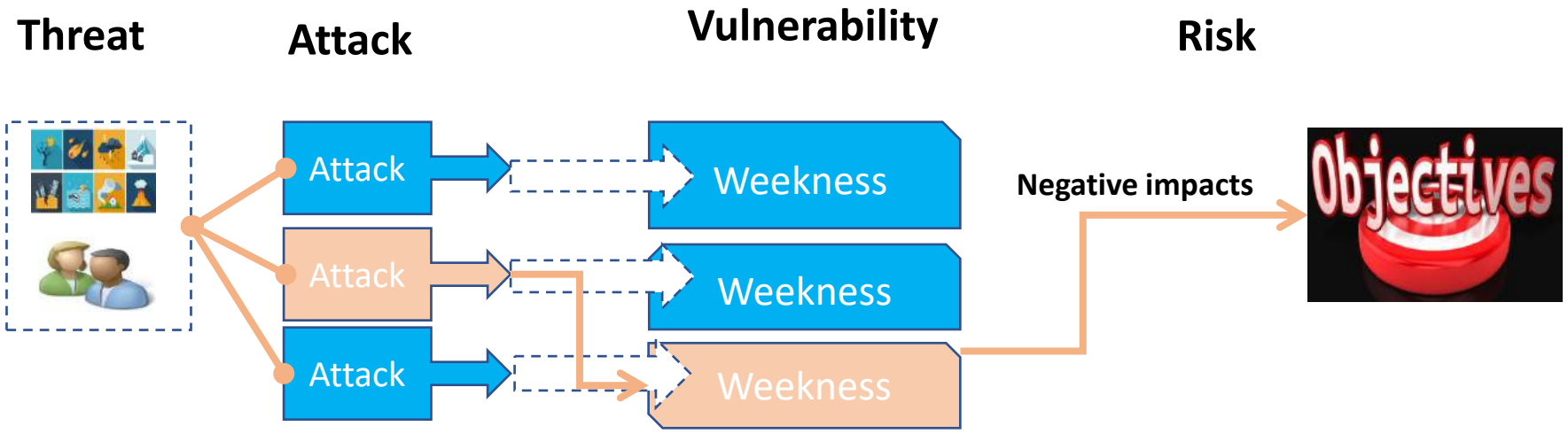
2.2. Hoạt động kiểm soát

2.3. Thông tin truyền thông

2.4. Giám sát

2.5. Môi trường kiểm soát

2.1. Đánh giá và phản ứng với rủi ro



- **Mục tiêu (objectives)**

- **Nguy cơ (Theat).** Bất kỳ sự kiện bất lợi nào hoặc sự kiện không mong muốn xảy ra, có thể làm tổn thương AIS hoặc tổ chức

- **Rủi ro (risk)**: là khả năng nguy cơ (threat) xẩy ra và thành công (vượt qua các kiểm soát) gây ra tác động bất lợi đến việc đạt được mục tiêu (theo COSO 2013; ERM 2004)

- **Điểm yếu/ Yếu kém** (vulnerability): là sự yếu kém của tài sản/nguồn lực/hệ thống mà có thể bị khai thác, lợi dụng bởi các cuộc tấn công / nguy cơ

2.1. Đánh giá và phản ứng với rủi ro

❖ Khái niệm

Ví dụ rủi ro (risk), nguy cơ (threat), điểm yếu/yếu kém (vulnerability)

Event- Sự kiện	Threat Nguy cơ	Vulnerability Điểm yếu/Yếu kém	Risk Rủi ro
Nhân viên bán hàng nghỉ việc	Nhân viên bán hàng nghỉ việc **bất mãn với công ty**	**Password** truy cập tập tin khách hàng **không thay đổi** kể từ khi nhân viên bất mãn nghỉ việc	Tập tin khách hàng bị truy cập bất hợp pháp để lấy danh sách KH

2.1. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment)

Mục tiêu

- Xác định các nguy cơ/ sự kiện bất lợi
- Đánh giá mưc độ của rủi ro
- Xác định RR còn lại của thủ tục KS dự định -> Tìm cách phản ứng với rủi ro
- Xác định lợi ích- chi phí- hiệu quả của hoạt động KS dự định → Chấp nhận hoạt động kiểm soát hay không

2.1. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment)



1. Làm sao nhận diện ra rủi ro?
2. Làm sao để ước tính rủi ro
3. Làm sao để xác định thiệt hại

2.1. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment): Nhận diện nguy cơ (threat)

Nguy cơ từ bên ngoài

- ***Thuộc Nền kinh tế (economic)***:Hoạt động, đặc điểm của nền kinh tế, đối thủ cạnh tranh
- ***Môi trường tự nhiên*** (natural environment)
- ***Thuộc Chính trị(Political):*** Bầu cử, thay đổi quản lý nhà nước, thay đổi thể chế
- ***Thuộc Xã hội (social):*** Thay đổi cấu trúc, quan niệm xã hội/gia đình; tội phạm;
- ***Thuộc Công nghệ (technological)***: công nghệ, kỹ thuật mới

Nguy cơ từ bên trong

- ***Cơ sở hạ tầng*** **(infrastructure).**
- ***Con người (personnel);*** sự cố tai nạn, gian lận, thời hạn hợp đồng lao động
- ***Qui trình (process)*** thực hiện hoạt động, qui trình sửa sai..
- ***Công nghệ (technology)***

2.1. Đánh giá và phản ứng với rủi ro

UEH UNIVERSITY

❖ Đánh giá rủi ro (risk assessment): Nhận diện nguy cơ

TABLE 5-1 Threats to Accounting Information Systems

THREATS	EXAMPLES
Natural and political disasters	Fire or excessive heat
	Floods, earthquakes, landslides, hurricanes, tornadoes, blizzards, snowstorms, and freezing rain
	War and attacks by terrorists
Software errors and equipment malfunctions	Hardware or software failure
	Software errors or bugs
	Operating system crashes
	Power outages and fluctuations
	Undetected data transmission errors
Unintentional acts	Accidents caused by human carelessness, failure to follow established procedures, and poorly trained or supervised personnel
	Innocent errors or omissions
	Lost, erroneous, destroyed, or misplaced data
	Logic errors
	Systems that do not meet company needs or cannot handle intended tasks
Intentional acts (computer crimes)	Sabotage
	Misrepresentation, false use, or unauthorized disclosure of data
	Misappropriation of assets
	Financial statement fraud
	Corruption
	Computer fraud—attacks, social engineering, malware, etc.

2.1. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment): Nhận diện nguy cơ

Đặc biệt lưu ý các nguy cơ từ sự cố tình (gian lận- intentional acts)

- Gian lận là bất cứ cách thức nào được sử dụng để đạt được lợi thế so với người khác (p 126)
- Gian lận về cơ bản là hành động che giấu sự thật để thu về các lợi ích cá nhân cho chính bản thân hoặc gây ra thiệt hại cho người khác. Các loại gian lận (xem bảng 5.1 slide 49)
- Ví dụ: báo cáo tài chính không trung thực, chiếm đoạt tài sản & hành vi bất hợp pháp như trộm cắp, tham nhũng, thông đồng, tham ô, rửa tiền, hối lộ, tống tiền

Gian lận là rủi ro nghiêm trọng gây hại cho DN không chỉ ở khía cạnh tài chính mà còn ở khía cạnh hình ảnh và danh tiếng của DN.

2.1. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment): Nhận diện nguy cơ

Đặc biệt lưu ý các nguy cơ từ sự cố tình (fraud)

Về mặt pháp lý, để một hành vi gian lận phải

- Tuyên bố, trình bày hoặc tiết lộ sai sự thật.
- Một sự kiện/vấn đề có tính trọng yếu khiến/thuyết phục/dụ dỗ một người hành động.
- Có ý định lừa dối.
- Tạo ra Một sự tin cậy chính đáng làm cho người khác dựa vào sự xuyên tạc để thực hiện một hành động.
- Thương tật, mất mát của nạn nhân.

❖ Đánh giá rủi ro (risk assessment): Nhận diện nguy cơ

Đặc biệt lưu ý các nguy cơ từ sự cố tình (fraud)

➢ Các loại gian lận (fraud)

- ***Tham nhũng (Corruption):***
  - là hành vi của những người nắm quyền (chức vụ, quyền hạn)
  - Liên quan đến các hành động bất hợp pháp, vô đạo đức hoặc không phù hợp với các tiêu chuẩn đạo đức.
  - Tham nhũng ví dụ: Hối lộ và gian lận đầu thầu .

2.1. Đánh giá và phản ứng với rủi ro

❖ **Đánh giá rủi ro (risk assessment): Nhận diện nguy cơ**

Đặc biệt lưu ý các nguy cơ từ sự cố tình (fraud)

- ***Gian lận đầu tư (Investment fraud)***: là trình bày sai hoặc bỏ qua sự thật nhằm thúc đẩy một khoản đầu tư hứa hẹn lợi nhuận cao với ít hoặc không có rủi ro. ví dụ gian lận chứng khoán
- ***Biển thủ tài sản*** (đôi khi được gọi là gian lận của nhân viên)
- ***Gian lận báo cáo tài chính*** (đôi khi được gọi là gian lận của quản lý). Hành vi cố ý hoặc thiếu thận trọng dẫn đến báo cáo tài chính sai lệch trọng yếu

2.2. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment):

- Ước tính khả năng rủi ro xẩy ra (likelihood/probability)
- Ước tính mức tác động (impact) của nguy cơ
- Xác định thiệt hại kỳ vọng (Potential loss) từ nguy cơ

Thiệt hại kỳ vọng (Potential loss) = **Khả năng nguy cơ/ rủi ro xẩy ra (likelihood/probability)** X **Mức tác động (impact)**

❖ Đánh giá rủi ro (risk assessment): Ví dụ

Tại công ty A, mỗi khi có sai sót dữ liệu thì cần xử lý lại toàn bộ bảng lương với chi phí là $10.000. Qui trình hiện nay, do không kiểm tra dữ liệu (validation test) trước xử lý nên xác suất xẩy ra sai sót dữ liệu là 15 %. Nếu công ty tốn chi phí $600 để thực hiện kiểm tra dữ liệu thì xác suất xẩy ra sai sót dữ liệu chỉ còn 1%.

Yêu cầu. Hãy xác định trong tình huống này

1. Nguy cơ? Điểm yếu? RR gì? Thủ tục kiểm soát dự định là gì?
2. Mức tác động (impact) gây ra bởi nguy cơ là bao nhiêu?
3. Mức thiệt hại kỳ vọng (expected loss) của RR trước và sau khi áp dụng thủ tục kiểm soát ?
4. Phân tích chi phí, lợi ích để xác định Công ty có nên áp dụng thủ tục kS dự định không?

2.1. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment): Ví dụ

	Nguy cơ (threat) Rủi ro (Risk)	Khả năng xẩy ra rủi ro (likelihood)	Mức tác động của RR (impact of risk)	Thiệt hại kỳ vọng (potential loss)
Nhận diện				
Hiện hành (trước thủ tục KS)				
Sau khi áp dụng thủ tục KS (Thủ tục .....)				
Lợi ích của thủ tục KS				
Chi phí của thủ tục KS				
Lợi ích ròng của thủ tục KS				

2.1. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment):

Rủi ro tiềm tàng (inherent risk)

- Phản ánh rủi ro vốn có, tiềm ẩn của tổ chức.
- Bản chất: là rủi ro khi chưa áp dụng thủ tục KS

Rủi ro còn lại (Residual risk)

- Rủi ro sau khi áp dụng kiểm soát hoặc các phản ứng khác với RR



Tại sao cần quan tâm tới rủi ro tiềm tàng và rủi ro còn lại?

2.1. Đánh giá và phản ứng với rủi ro

- **Đánh giá rủi ro (risk assessment):**

Tiếp cận Đánh giá rủi ro trong thiết kế KSNB

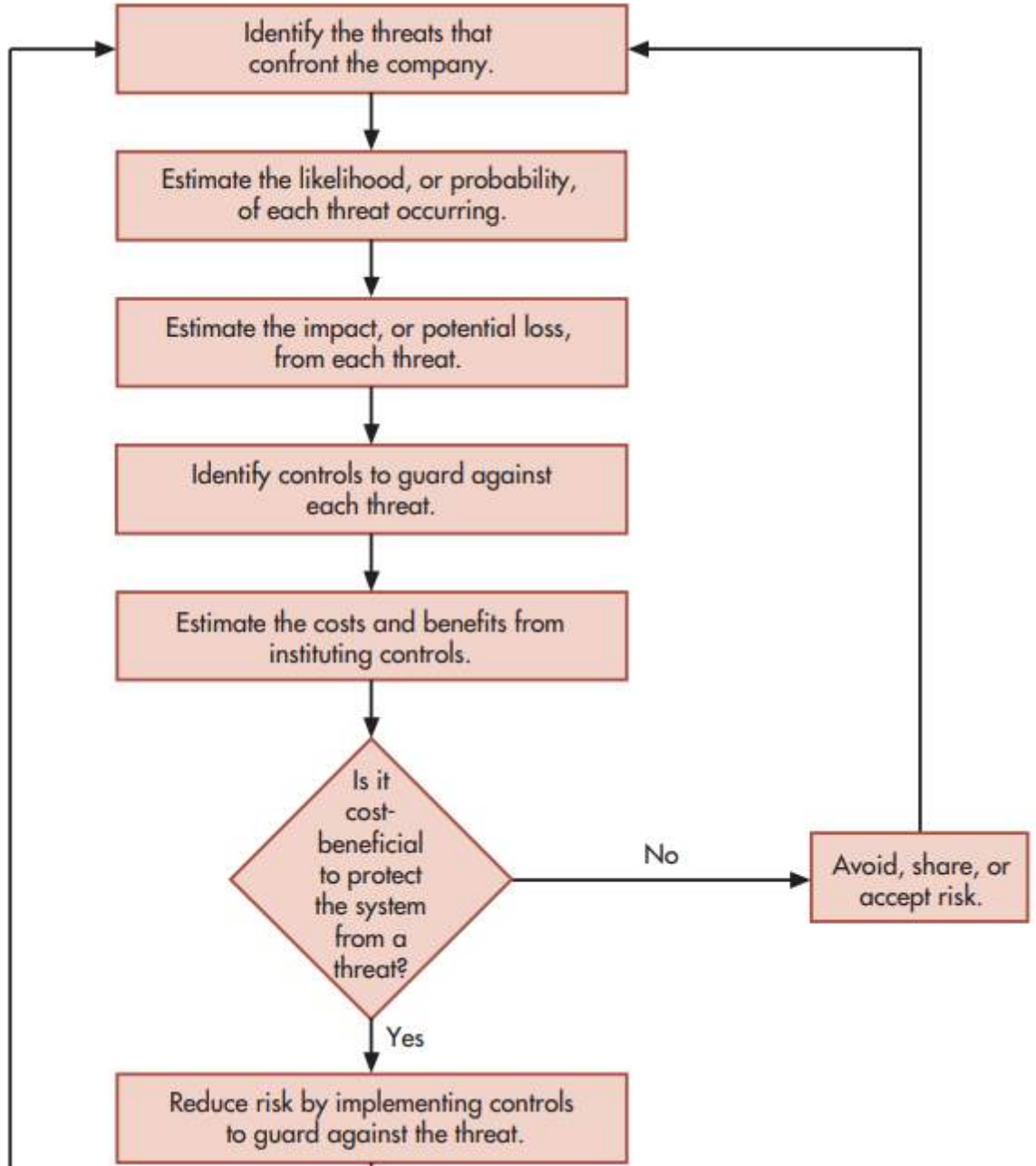


FIGURE 10-3
Risk Assessment Approach to Designing Internal Controls

2.1. Đánh giá và phản ứng với rủi ro

❖ Đánh giá rủi ro (risk assessment):



Quyết định thế nào?

Lợi ích- chi phí của thủ tục KS dự định áp dụng

- Xác định/Lựa chọn kiểm soát
- Đánh giá chi phí, lợi ích của kiểm soát lựa chọn
  - Lợi ích: RR mất đi sau khi áp dụng thủ tục KS (chênh lệch RR tiềm tàng & RR còn lại)
  - Chi phí:
  - Cân nhắc:
    - ✓ Lợi ích – chi phí> 0:
    - ✓ Lợi ích –chi phí <0:

2.1. Đánh giá và phản ứng với rủi ro

❖ Phản ứng với rủi ro (risk response):

- **Giảm thiểu (reduce)** : giảm khả năng xảy ra và tác động của rủi ro bằng cách thực hiện kiểm soát nội bộ hữu hiệu
- **Chia sẻ/ chuyển giao rủi ro (share)**: chia sẻ rủi ro hoặc chuyển nó cho đối tác khác bằng cách mua bảo hiểm hoặc thuê ngoài một hoạt động
- **Chấp nhận (accept)**: chấp nhận khả năng xảy ra và tác động của rủi ro
- **Né tránh (avoid)**: né tránh rủi ro bằng cách không tham gia vào các hoạt động tạo ra rủi ro. Điều này có thể đòi hỏi công ty phải bán một bộ phận, bỏ một dòng sản phẩm hoặc không mở rộng thị trường như dự đoán

2.1. Đánh giá và phản ứng với rủi ro

❖ Phản ứng với rủi ro (risk response):



Chiến lược lựa chọn các phản ứng này thế nào?

- ❖ Cân nhắc giữa ***RR còn lại*** và ***khả năng chấp nhận RR (risk tolerance)***
  - ❖ Nếu thủ tục KS không hiệu quả thì cân nhắc:
    - Nếu thiệt hại kỳ vọng nằm trong khả năng chịu đựng RR (Risk tolerance) và không có cách gì giảm thiểu RR -> Chấp nhận RR (accepted)
    - Nếu chia sẻ RR làm RR còn lại giảm xuống mức nằm trong khả năng chịu đựng RR –risk tolerance → Chia sẻ RR (share)
    - Nếu ko thể giảm thiệt hại kỳ vọng xuống mức nằm trong khả năng chịu đựng RR –risk tolerance → Né Tránh (avoid)

2.1. Đánh giá và phản ứng với rủi ro



❖Câu hỏi: Hãy phân biệt:

- Sự kiện (event) - Nguy cơ (threat)
- Nguy cơ (threat) - Rủi ro (risk)
- Gian lận - Nguy cơ -Rủi ro

❖ Câu hỏi: Mối quan hệ

- Rủi ro tiềm tàng- Rủi ro còn lại: Khả năng xẩy ra RR, Mức tác động, Thiệt hại kỳ vọng
- Có bao nhiêu kiểu phản ứng rủi ro?
- Các khái niệm trên liên quan với nhau thế nào trong qui trình thiết kế các hoạt động kiểm soát của đơn vị

2.2. Các hoạt động kiểm soát

- Hoạt động kiểm soát là các **chính sách và thủ tục** mà ban quản lý triển khai trong doanh nghiệp, ở tất cả các cấp, và trong tất cả các chức năng, nhằm đảm bảo hợp lý rằng các mục tiêu kiểm soát đạt được và phản ứng rủi ro được thực hiện.

• Chính sách

- Là những nguyên tắc, là cơ sở cho việc thực hiện các thủ tục
- Cần phải được viết bằng văn bản, thực hiện xuyên suốt và nhất quán trong DN.
- Thường được truyền đạt bằng văn bản, hiệu quả khi chính sách dễ hiểu & tồn tại lâu dài trong DN

• Thủ tục

- Là những qui trình, biện pháp cụ thể để thực thi chính sách

2.2. Các hoạt động kiểm soát

❖ Phân loại:

Ngoài việc phân loại theo mục tiêu kiểm soát (chiến lược, hoạt động, báo cáo, tuân thủ), hoạt động kiểm soát còn được phân theo (P324):

- **Kiểm soát ngăn ngừa (Preventive controls)**: là các KS ngăn chặn các vấn đề trước khi chúng phát sinh
- **Kiểm soát phát hiện** (Detective controls): là các KS để phát hiện ra các vấn đề chưa được ngăn chặn
- **Kiểm soát sửa chữa** (Corrective controls): là các kiểm soát xác định và sửa sai các vấn đề, đồng thời sửa chữa lại các kết quả lỗi

2.2. Các hoạt động kiểm soát

❖ Phân loại:

- For Technology (P.324)
  - General controls- Kiểm soát chung p324. Controls designed to make sure an organization's information system and control environment is stable and well managed
  - Application controls- Kiểm soát ứng dụng. Controls that prevent, detect, and correct transaction errors and fraud in application programs

2.2. Các hoạt động kiểm soát

❖Các thủ tục kiểm soát cụ thể:

- Ủy quyền phù hợp cho nghiệp vụ và hoạt động
- Phân chia trách nhiệm
- Kiểm soát phát triển hệ thống
- Kiểm soát quản trị việc thay đổi (*chương 5*)
- Thiết kế và sử dụng chứng từ, sổ sách
- Đảm bảo an toàn cho tài sản, sổ sách và dữ liệu
- Kiểm tra độc lập việc thực hiện

Lưu ý: Hoạt động kiểm soát được thực hiện tại:

- **Tất cả các cấp độ**
- **Gắn cùng các giai đoạn hoạt động KD**
- **Bao trùm cả môi trường CNTT**

2.2. Các hoạt động kiểm soát

❖ Ủy quyền hoạt động phù hợp

Do khó khăn trong việc giám sát từng hoạt động và quyết định của DN, ban quản lý thiết lập các chính sách cho nhân viên tuân theo và sau đó trao quyền cho họ. Việc **trao quyền này được gọi là ủy quyền**

- **Cách thức thực hiện việc ủy quyền**:
  - Ký tài liệu, chứng từ hoặc báo cáo
  - Nhập mã ủy quyền (authorization code) trên hệ thống
  - Chữ ký điện tử
- **Phân loại:**
  - Ủy quyền đặc biệt (specific authorization)
  - Ủy quyền chung (general authorization)

2.2. Các hoạt động kiểm soát

❖ Phân chia trách nhiệm

➢ Yêu cầu

- 1 cá nhân không không làm quá nhiều trách nhiệm trong toàn qui trình kinh doanh
- 1 cá nhân không ở vị trí thực hiện và che giấu gian lận

➢ Lưu ý

- **Phân chia trách nhiệm kế toán** (trong nhóm người sử dụng/ thực hiện qui trình kinh doanh)
- **Phân chia trách nhiệm trong chức năng của hệ thống máy tính (chương 5)**

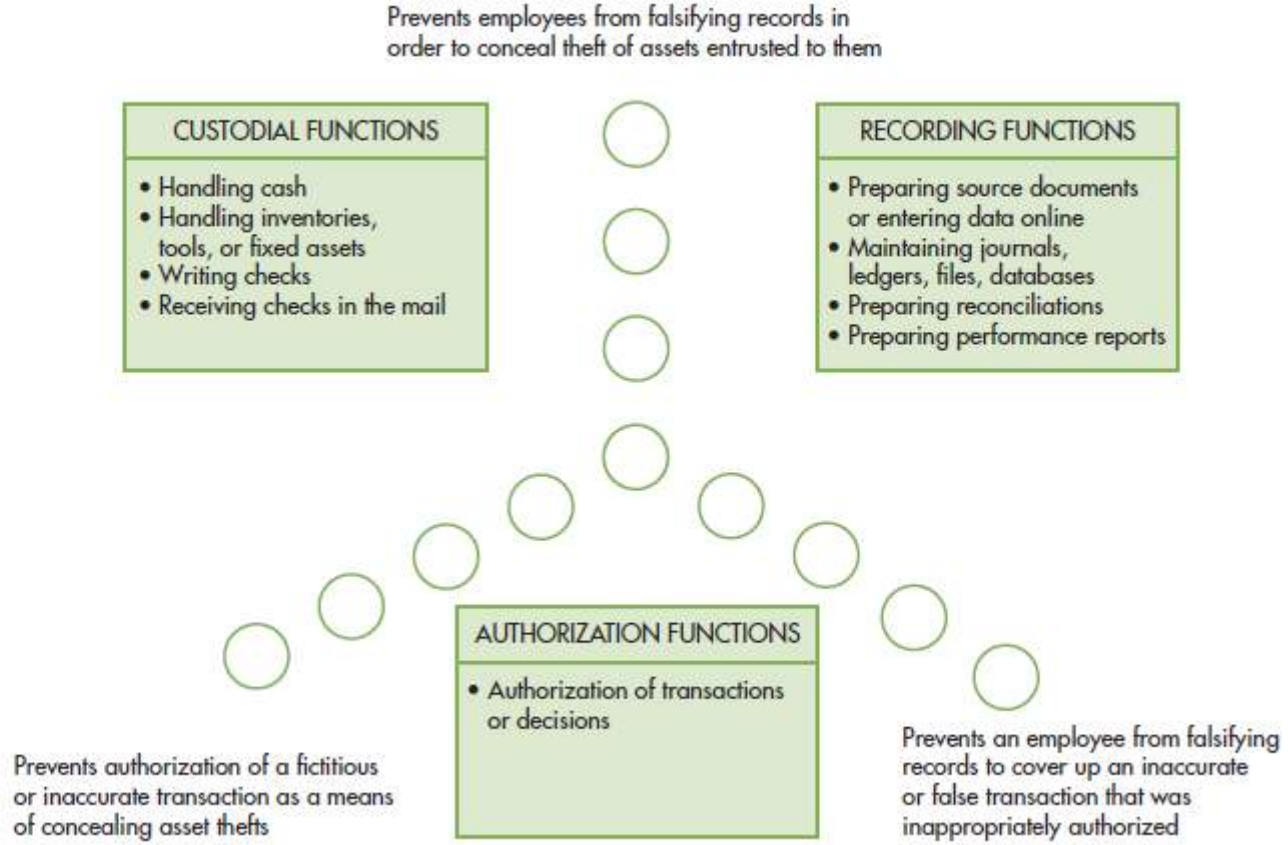
2.2. Các hoạt động kiểm soát

❖ Phân chia trách nhiệm: Kế toán

❖ Phân chia trách nhiệm kế toán: Nguyên tắc áp dụng

- Xét cùng loại tài sản
- Cùng loại hoạt động

FIGURE 7-5
Separation of Duties



2.2. Các hoạt động kiểm soát

❖ Kiểm soát phát triển & hình thành hệ thống

KS phát triển và hình thành HT gồm các thủ tục KS liên quan đến việc **phê duyệt của ban quản lý, sự tham gia của người dùng** trong quá trình phân tích, thiết kế, thử nghiệm, triển khai và chuyển đổi HT

- **Một số thủ tục kiểm soát**
  - Ban chỉ đạo (steering committee) cần hướng dẫn và giám sát việc phát triển và hình thành hệ thống
  - Kế hoạch chiến lược tổng thể (Strategic master plan) cần được phát triển và cập nhật hàng năm
  - Thiết lập một kế hoạch phát triển dự án chi tiết (Project development plan)
  - Xây dựng một lịch trình xử lý dữ liệu để chỉ ra khi nào mỗi tác vụ sẽ được thực hiện
  - Thiết lập các hoạt động đo lường thành quả (performance measurement) của hệ thống để đánh giá hệ thống
  - Tiến hành việc đánh giá sau khi thực hiện (review)

2.2. Các hoạt động kiểm soát

❖ Thiết kế và sử dụng chứng từ, sổ sách

- Thiết kế và sử dụng chứng từ (chứng từ điện tử hoặc chứng từ giấy) phù hợp nhằm đảm bảo ghi nhận đầy đủ, chính xác tất cả dữ liệu của các nghiệp vụ liên quan.
- Cần lưu ý:
  - Mẫu biểu và nội dung đơn giản, giảm thiểu lỗi và dễ kiểm tra đối chiếu
  - Chứng từ bắt đầu một giao dịch cần được xét duyệt
  - Chứng từ nên được đánh số trước
  - Cung cấp dấu vết kiểm toán

2.2. Các hoạt động kiểm soát

- **Thiết kế và sử dụng chứng từ, sổ sách**
  - **Ví dụ**

TABLE 24-5 Principles of Good Form Design

General Considerations
- Are preprinted data used as much as possible?
- Are the weight and grade of the paper appropriate for the planned use?
- Do bold type, lines, and shading highlight different parts of the form?
- Is the form a standard size?
- Is the form size consistent with filing, binding, or mailing requirements?
- If the form is mailed, will the address show in a window envelope?
- Are copies printed in different colors to facilitate proper distribution?
- Do clear instructions explain how to complete the form?

Introduction
- Does the form name appear at the top in bold type?
- Is the form consecutively prenumbered?
- Is the company name and address preprinted on forms sent to external parties?

Main Body
- Is logically related information (e.g., customer name, address) grouped together?
- Is there sufficient room to record each data item?
- Is data entry consistent with the sequence in which the data are acquired?
- Are codes or check-offs that are used instead of written entries adequately explained?

Conclusion
- Is space provided to record the final disposition of the form?
- Is space provided for a signature(s) to indicate transaction approval?
- Is space provided to record the approval date?
- Is space provided for a dollar or numeric total?
- Is the distribution of each copy of the form clearly indicated?

2.2. Các hoạt động kiểm soát

An toàn tài sản, sổ sách và dữ liệu

Một số lưu ý:

- Tạo ra và thực thi các chính sách và thủ tục phù hợp
- Duy trì ghi nhận chính xác cho tất cả tài sản
- Hạn chế tiếp cận với tài sản của DN
- Bảo vệ sổ sách/ báo cáo và chứng từ

2.2. Các hoạt động kiểm soát

❖ Kiểm tra độc lập

Được thực hiện bởi một nhân viên không phải là người thực hiện hoạt động ban đầu, nhằm đảm bảo các nghiệp vụ được xử lý chính xác.

➢ Kiểm tra độc lập bao gồm những hoạt động sau:

- Thực hiện những đánh giá định kỳ của quản lý cấp cao
  - So sánh (1) thực hiện và kế hoạch; (2) Thực hiện và kỳ trước; (3) Thực hiện và đối thủ cạnh tranh
- Đánh giá phân tích (analytical review). Kiểm tra, so sánh các bộ dữ liệu khác nhau
- Đối chiếu sổ sách/ báo cáo có nguồn độc lập
- So sánh giữa số lượng thực tế vào số lượng trên sổ sách
- Kế toán ghi kép
- Đánh giá độc lập

2.3. Thông tin truyền thông

Hệ thống thông tin và truyền thông cần thu thập, xử lý để tạo ra các thông tin thích hợp và chất lượng cao để thực hiện, quản lý và kiểm soát hoạt động của tổ chức

- Thu thập , xử lý nghiệp vụ tạo báo cáo tin cậy
- Cung cấp dấu vết kiểm toán để kiểm tra, truy xuất thông tin trên báo cáo
- Thông tin phù hợp được xác định, thu thập và truyền đạt trong một biểu mẫu và khung thời gian cho phép các bên liên quan trong và ngoài tổ chức thực hiện trách nhiệm của họ

2.3. Thông tin truyền thông

- HT thông tin cần **truyền thông trong nội bộ**
- HT thông tin cần **truyền thông với bên ngoài và chiều ngược lại (**Cổ đông, bên hợp tác, chủ sở hữu, khách hàng, phân tích tài chính, quản lý nhà nước)

Các vấn đề

- Thông tin cần thiết về HT KSNB (mục tiêu, trách nhiệm, chính sách, qui trình, đánh giá)
- Thông tin đánh giá hoạt động của DN từ bên ngoài
- Tạo các kênh và phương pháp truyền thông phù hợp (từ trên xuống, dưới lên, theo chiều ngang)

2.4. Giám sát

- Hệ thống kiểm soát nội bộ phải được giám sát, đánh giá liên tục và sửa đổi khi cần thiết. Bất kỳ sự thiếu sót nào cũng phải được báo cáo cho cấp quản lý và ban giám đốc.

❖ Một số phương pháp giám sát kết quả hoạt động của DN như:

- Thực hiện các đánh giá kiểm soát nội bộ
- Triển khai giám sát hiệu quả
- Sử dụng hệ thống kế toán trách nhiệm
- Giám sát các hoạt động của hệ thống
- Theo dõi phần mềm và thiết bị di động đã mua
- Tiến hành kiểm toán định kỳ
- Sử dụng một nhân viên an ninh máy tính (CSO) và một giám đốc tuân thủ (CCO)
- Sử dụng các chuyên gia điều tra gian lận kỹ thuật số (computer forensics specialist)
- Cài đặt phần mềm phát hiện gian lận
- Triển khai số điện thoại khẩn để báo cáo gian lận

2.5. Môi trường kiểm soát

Môi trường kiểm soát, hay là văn hóa doanh nghiệp, tác động đến ý thức của mọi người trong DN, cụ thể:

- Chi phối ban quản lý trong việc thiết lập chiến lược & mục tiêu, tổ chức các hoạt động kinh doanh, xác định, đánh giá và phản ứng rủi ro.
- Tác động đến hành vi ứng xử của nhân viên

❖ **Môi trường kiểm soát bao gồm**:

- Triết lý quản lý, phong cách điều hành
- Cam kết về tính trung thực, giá trị đạo đức và quyền hạn
- Hội đồng quản trị giám sát kiểm soát nội bộ
- Cơ cấu tổ chức
- Các phương pháp phân định quyền hạn và trách nhiệm
- Chính sách nhân sự
- Các yếu tố tác động bên ngoài

2.5. Môi trường kiểm soát

❖ Triết lý quản lý, phong cách điều hành

- Triết lý quản lý & phong cách điều hành tác động đến cách thức DN được điều hành. Cụ thể, nó ảnh hưởng đến chính sách, thủ tục, sự truyền đạt (bằng lời & văn bản) và các quyết định. .
- Triết lý quản lý & phong cách điều hành được thể hiện càng có trách nhiệm, được truyền đạt càng rõ ràng thì nhân vi sẽ hành xử càng có trách nhiệm hơn

2.5. Môi trường kiểm soát

❖ Cam kết về tính trung thực, giá trị đạo đức & quyền hạn

- Các DN cần một nền tảng văn hóa nhấn mạnh đến tính chính trực, sự cam kết về giá trị đạo đức và quyền hạn.
- Được lan tỏa mạnh mẽ qua việc làm gương của bản thân nhà quản lý.

- **Tính chính trực & giá trị đạo đức được truyền đạt bằng cách**:
  - Tích cực giảng dạy
  - Tránh mong đợi phi thực tế hoặc khuyến khích những hành động không trung thực hoặc bất hợp pháp
  - Khen thưởng sự chính trực của nhân viên một cách nhất quán, đưa ra tên gọi đối với hành vi nào là trung thực, hành vi nào không
  - Phát triển một bộ qui tắc ứng xử bằng văn bản, mô tả rõ các hành vi trung thực và không trung thực
  - Yêu cầu nhân viên báo cáo hành vi không trung thực hoặc bất hợp pháp
  - Cam kết về năng lực

2.5. Môi trường kiểm soát

❖ Hội đồng quản trị (board of directors) giám sát kiểm soát nội bộ

- Hệ thống quản trị doanh nghiệp nhắm tới 2 mục tiêu:
  - Loại trừ những xung đột về lợi ích (của người quản lý điều hành và cổ đông.
  - Sử dụng tài sản của công ty để đảm bảo lợi ích cao nhất của cổ đông và nhà đầu tư



- Hội đồng quản trị (HĐQT) đại diện cho cổ đông, **giám sát** hoạt động của ban giám đốc **một cách độc lập**
  - HĐQT đánh giá ban quản lý và các quyết định của ban quản lý
- HĐQT phê duyệt các chiến lược DN và xem xét các chính sách bảo mật

2.5. Môi trường kiểm soát

❖ Hội đồng quản trị (board of directors) giám sát kiểm soát nội bộ

- HĐQT ảnh hưởng sự hữu hiệu của hệ thống KSNB
  - Các DN niêm yết cần có Ủy ban kiểm toán (Audit committee) là ủy ban chuyên trách của HĐQT, chịu trách nhiệm đối với bctc, sự tuân thủ qui định, kiểm soát nội bộ & việc thuê mướn, giám sát các KTV nội bộ và KTV độc lập
    - Sự hữu hiệu của HĐQT và UB kiểm toán phụ thuộc vào:
      - Sự độc lập của HĐQT và UB kiểm toán với ban điều hành DN
      - Sự phối hợp giữa HĐQT& UB kiểm toán với ban điều hành

2.5. Môi trường kiểm soát

❖ Cơ cấu tổ chức

Cơ cấu tổ chức của công ty cung cấp một khung/nền cho việc lập kế hoạch, thực hiện, kiểm soát và giám sát các hoạt động.

- Các khía cạnh quan trọng của cơ cấu tổ chức:
  - Quyền hạn tập trung hoặc phân tán
  - Mối quan hệ về báo cáo, (trực tiếp hay không trực tiếp); yêu cầu thông tin
  - Tổ chức theo ngành, dòng sản phẩm, vị trí địa lý hoặc hệ thống tiếp thị
  - Tổ chức mối quan hệ trong ủy quyền (lines of authority), xét duyệt cho các chức năng kế toán, kiểm toán và hệ thống thông tin
  - Qui mô và bản chất hoạt động của DN

❖ Phương pháp phân chia quyền hạn và trách nhiệm

Phân chia quyền hạn và trách nhiệm:

- Xác định mức quyền hạn của từng phòng ban, cá nhân trong công việc
- Trách nhiệm báo cáo với các cấp có liên quan

Phương pháp phân chia quyền hạn và trách nhiệm

- Cách tiếp cận phân chia quyền hạn và trách nhiệm

- Nhà quản lý cần đảm bảo các nhân viên hiểu được mục tiêu DN, phân chia quyền hạn và trách nhiệm đối với mục tiêu cho từng phòng ban và cá nhân

- Phân chia Quyền hạn và trách nhiệm được thiết kế và truyền đạt bằng cách: sử dụng mô tả công việc chính thức, đào tạo nhân viên, lịch trình hoạt động, ngân sách, quy tắc ứng xử và chính sách, thủ tục bằng văn bản.

2.5. Môi trường kiểm soát

❖ Chính sách nhân sự

- Chính sách nhân sự chi phối sự trung thực và lòng trung thành của nhân viên.
- Chính sách nhân sự cần yêu cầu rõ ràng về mức độ chuyên môn, năng lực, hành vi đạo đức và tính chính trực.

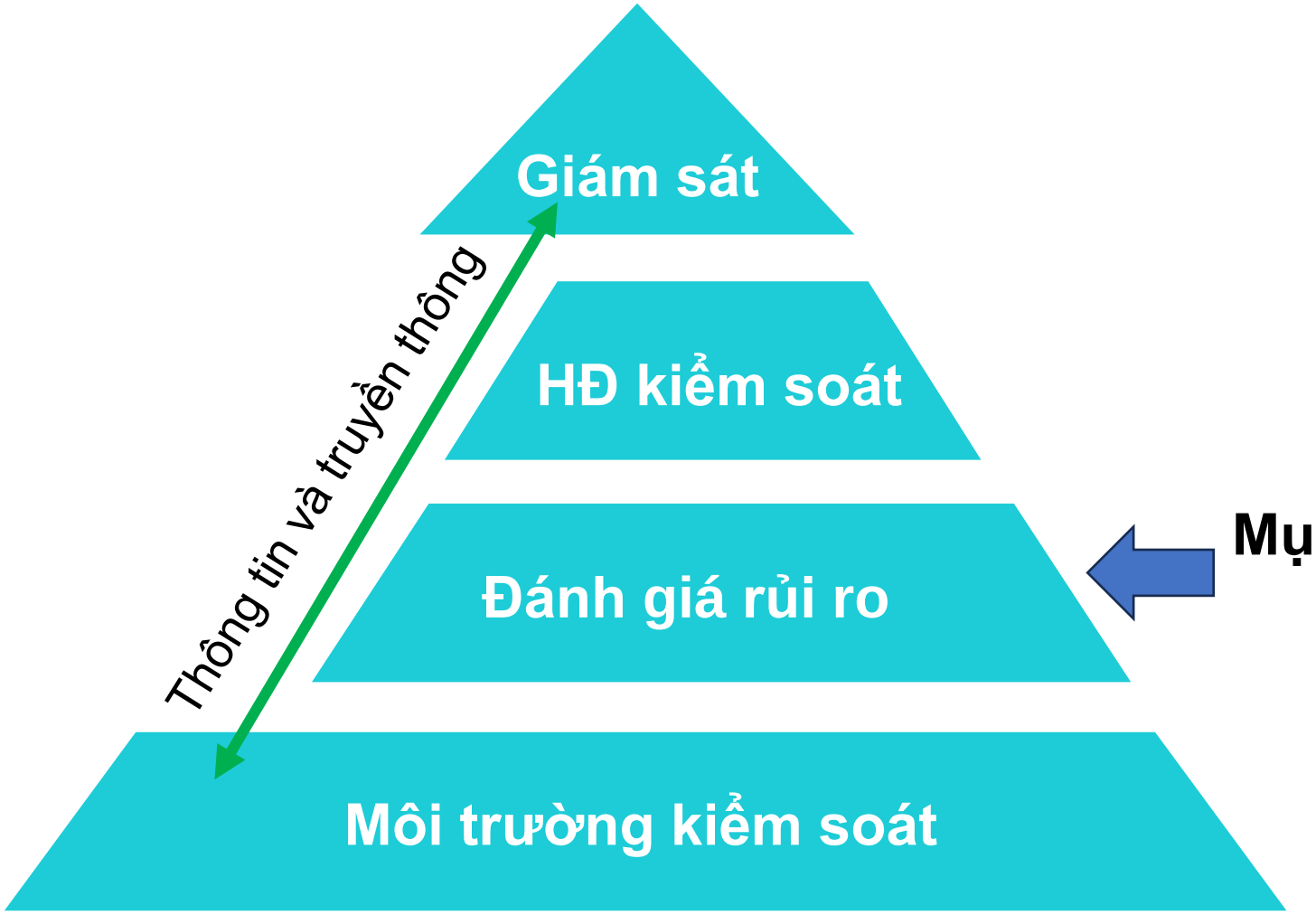
- Chính sách nhân sự bao gồm các chính sách và thủ tục liên quan đến việc:
  - Tuyển dụng
  - Bồi thường, đánh giá và thăng tiến
  - Đào tạo
  - Quản lý nhân viên bất mãn
  - Thôi việc
  - Khen thưởng
  - Luân chuyển nhân sự
  - Hợp đồng bảo mật thông tin

2.5. Môi trường kiểm soát

❖Các yếu tố tác động bên ngoài

- Các yếu tố tác động bên ngoài bao gồm yêu cầu được đưa ra bởi các cơ quan quản lý, thị trường chứng khoán…

3. Mối quan hệ giữa các thành phần KSNB



Mục tiêu kiểm soát

Các thành phần không tách rời mà có quan hệ lẫn nhau, cùng tồn tại trong một hệ thống kiểm soát nội bộ

3. Mối quan hệ giữa các thành phần KSNB

Nhận xét về khái niệm KSNB

Kiểm soát nội bộ (internal control). Là quá trình được thực hiện để cung cấp ***sự đảm bảo hợp lý*** rằng các ***mục tiêu kiểm soát đạt*** được:

- KSNB là quá trình/qui trình liên tục, thường xuyên gắn cùng hoạt động hàng ngày của tổ chức
- Quá trình này được thiết kế (nhà quản lý thiết lập) và vận hành (nhà quản lý và nhân viên) -> Nó bị chi phối/bị ảnh hưởng bởi con người
- Đảm bảo hợp lý đạt được mục tiêu:
  - Hiểu biết, Sai lầm của con người trong quá trình thiết kế và vận hành KSNB
  - Thông đồng
  - Lạm quyền quản lý
  - Chi phí, hiệu quả thủ tục kiểm soát

4. Giới thiệu 3 khuôn mẫu Kiểm soát

UEH UNIVERSITY

Phụ lục

4.1. Khuôn mẫu COBIT của ISACA

4.2. Khuôn mẫu IC của COSOInt

4.3. Khuôn mẫu ERM của COSO (Enterprise Risk Management: integrated Framework)

4.4. So sánh IC và ERM

4. Giới thiệu 3 khuôn mẫu Kiểm soát

Giới thiệu 3 khuôn mẫu:

- Khuôn mẫu kiểm soát nội bộ COSO (internal control-integrated framework) - báo cáo lần 1 (1992; lần 2: 2013)
- Quản trị rủi ro doanh nghiệp ERM (enterprise risk management: integrated framework) của COSO. Báo cáo lần đầu 2004; cập nhật 2017 & 2018
- Khuôn mẫu COBIT của ISACA

4. Giới thiệu 3 khuôn mẫu Kiểm soát

Ủy ban các tổ chức bảo trợ COSO

- **Khuôn mẫu kiểm soát nội bộ (Internal control): IC**
- **Khuôn mẫu quản trị rủi ro doanh nghiệp (ERM)**

Hiệp hội kiểm toán & kiểm soát hệ thống thông tin ISACA

- **Khuôn mẫu COBIT**

COSO (Committee of Sponsoring Organization) là 1 nhóm khu vực tư, bao gồm: (1) American Accounting Association). (2) American institute of certified public accountants (AICPA) ; (3) the institute of international Auditors; (3) the Institute of Management Accountants; (5) Financial Executives Institute.

ISACA (Information Audit and Control Association.)

4. Giới thiệu 3 khuôn mẫu Kiểm soát

COBIT (control Objectives for Information and related Tecnology)

Là một khuôn mẫu về an toàn và kiểm soát giúp

- Ban quản lý đánh giá các biện pháp an toàn và kiểm soát của môi trường công nghệ thông tin (CNTT)
- Người dùng dịch vụ CNTT được bảo đảm có đủ an toàn và kiểm soát
- Kiểm toán viên chứng minh được những ý kiến kiểm soát nội bộ của họ và tư vấn về các vấn đề an toàn và kiểm soát CNTT

4. Giới thiệu 3 khuôn mẫu Kiểm soát

Khuôn mẫu kiểm soát nội bộ của COSO (Internal control - integrated framework)

- 1992: báo cáo lần 1: 3 mục tiêu KS, 5 thành phần: khái niệm
- 2013: báo cáo lần 2: 3 mục tiêu KS, 5 thành phần: Khái niệm và 17 nguyên tắc

4. Giới thiệu 3 khuôn mẫu Kiểm soát

Khuôn mẫu kiểm soát nội bộ của COSO (Internal control - integrated framework) 2013

Component	Description
Control environment	This is the foundation for all other components of internal control. The core of any business is its people—their individual attributes, including integrity, discipline, ethical values, and competence—and the environment in which they operate. They are the engine that drives the organization and the foundation on which everything rests. 1. Commitment to integrity and ethics 2. Internal control oversight by the board of directors, independent of management 3. Structures, reporting lines, and appropriate responsibilities in the pursuit of objectives established by management and overseen by the board 4. A commitment to attract, develop, and retain competent individuals in alignment with objectives 5. Holding individuals accountable for their internal control responsibilities in pursuit of objectives

Khuôn mẫu kiểm soát nội bộ của COSO (Internal control - integrated framework) 2013

Component	Description
Risk assessment	The organization must identify, analyze, and manage its risks. Managing risk is a dynamic process. Management must consider changes in the external environment and within the business that may be obstacles to its objectives. 6. Specifying objectives clearly enough for risks to be identified and assessed 7. Identifying and analyzing risks to determine how they should be managed 8. Considering the potential of fraud 9. Identifying and assessing changes that could significantly impact the system of internal control

Khuôn mẫu kiểm soát nội bộ của COSO (Internal control - integrated framework) 2013

Component	Description
Control activities	Control policies and procedures help ensure that the actions identified by management to address risks and achieve the organization's objectives are effectively carried out. Control activities are performed at all levels and at various stages within the business process and over technology. 10. Selecting and developing controls that might help mitigate risks to an acceptable level 11. Selecting and developing general control activities over technology 12. Deploying control activities as specified in policies and relevant procedures

Khuôn mẫu kiểm soát nội bộ của COSO (Internal control - integrated framework) 2013

Component	Description
Information and communication	Information and communication systems capture and exchange the information needed to conduct, manage, and control the organization's operations. Communication must occur internally and externally to provide information needed to carry out day-to-day internal control activities. All personnel must understand their responsibilities. 13. Obtaining or generating relevant, high-quality information to support internal control 14. Internally communicating information, including objectives and responsibilities, necessary to support the other components of internal control 15. Communicating relevant internal control matters to external parties

Khuôn mẫu kiểm soát nội bộ của COSO (Internal control - integrated framework) 2013

Component	Description
Monitoring	The entire process must be monitored, and modifications made as necessary so the system can change as conditions warrant. Evaluations ascertain whether each component of internal control is present and functioning. Deficiencies are communicated in a timely manner, with serious matters reported to senior management and the board. 16. Selecting, developing, and performing ongoing or separate evaluations of the components of internal control 17. Evaluating and communicating deficiencies to those responsible for corrective action, including senior management and the board of directors, where appropriate

4. Giới thiệu 3 khuôn mẫu Kiểm soát

ERM- Khuôn mẫu Quản trị rủi ro DN (Enterprise risk Management- integrated framework) của COSO (p329)

- 2004: Phát hành báo cáo ERM: Nguyên tắc cơ bản của ERM: 4 mục tiêu kiểm soát, 8 thành phần,
- 2017: Phát hành báo cáo "(Enterprise risk Management- Integrating with Strategy and Performance): 5 thành phần, 20 nguyên tắc
- 2018: Phát hành hướng dẫn "Improving Organizational Resiliency: New Guidance Addresses Environmental, Social, and Governance-related Risks (ESG)"

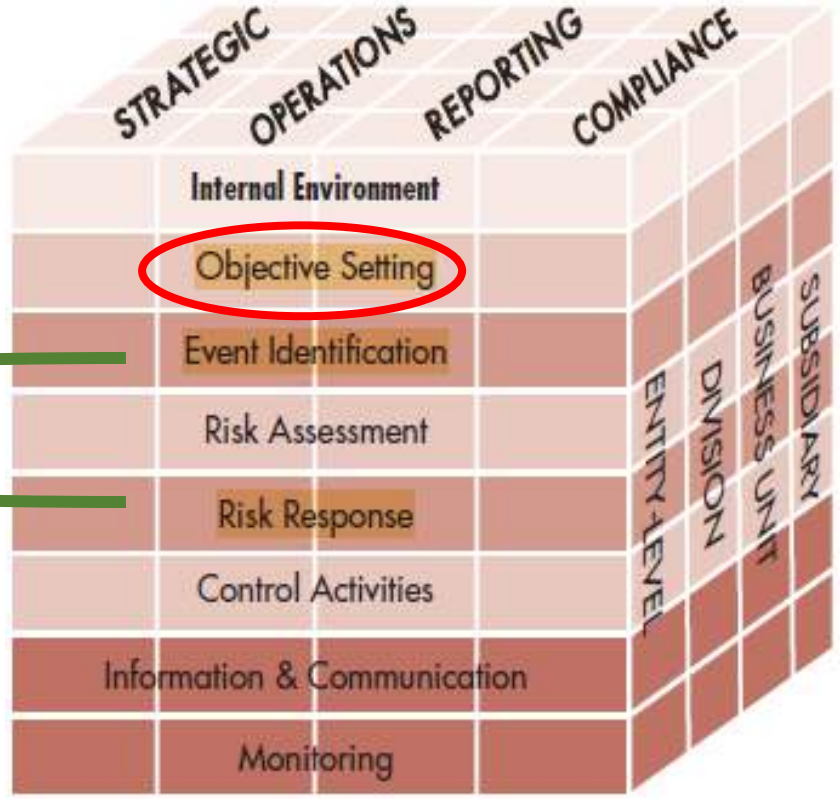
4. Giới thiệu 3 khuôn mẫu Kiểm soát

So sánh giữa IC và ERM

- **Khuôn mẫu Kiểm soát nội bộ COSO (Internal Control-**



- **Khuôn mẫu ERM**



4. Giới thiệu 3 khuôn mẫu Kiểm soát

So sánh giữa IC và ERM

❖ **(Internal Control- Integrated Framework) - Báo cáo lần 1 (1992; lần 2: 2013**

- **Mục tiêu IC** (1) hoạt động; (2) báo cáo ; (3) tuân thủ.
- **Cách tiếp cận**: trên cơ sở kiểm soát
- Phạm vi ảnh hưởng
- Đặt nặng tính chính xác, tuân thủ
- Được áp dụng rộng rãi để đánh giá kiểm soát nội bộ theo yêu cầu của SOX

❖ **(Enterprise Risk Management: integrated Framework) : 2004; 2017 & 2018**

- **Mục tiêu** (1)Chiến lược;(2) hoạt động;(3) báo cáo;(4) tuân thủ .
- **Cách tiếp cận** trên cơ sở rủi ro; Nhấn mạnh đến qui trình quản lý rủi ro
- Phạm vi ảnh hưởng:
- Toàn diện hơn IC, được sử dụng để xây dựng chiến lược, mục tiêu

Tổng kết